

A2A Threat Model

Day 1 · after Module 3 (Agent to Agent) · 25 min · pods of 3–5 · whiteboard

Objective. Threat-model **your own pod's case**. Draw the agents and their privileges, mark the trust boundary and the highest-privilege action, trace the shortest attack path to it, and place one control that breaks the path.

- THE 5-STEP A2A THREAT MODEL
1. **Map the agents.** List every agent or component, and **who runs it** — you, a vendor, or the user.
 2. **Label privileges.** For each: what can it **read, write, execute**? Mark the single **highest-privilege action** in the whole system.
 3. **Draw the trust boundary.** The line between what you control and what you don't. Anything crossing it — vendor agents, user input, fetched data — is **untrusted**.
 4. **Trace the worst path.** From the highest-privilege action, work backwards: what's the **shortest path** from outside the boundary to triggering it?
 5. **Place one control.** The **smallest** control that breaks that path.

- A2A CONCEPTS FROM MODULE 3
- **Trust boundary** — the perimeter of what you control; vendor agents and user/fetched data sit outside it.
 - **Least privilege** — an agent should hold only the rights its task needs, nothing more.
 - **Non-human identity (NHI)** — each agent's own credentials; if one agent can reach another's, privilege separation is fiction.
 - **Cross-agent injection (XPJA)** — untrusted content read by a low-privilege agent becomes instructions that reach a high-privilege one.
 - **Confused deputy** — a trusted high-privilege agent is tricked into acting on a malicious request that came from outside.

Draw it (on the whiteboard)

boxes = agents | label each R / W / X | dashed line = trust boundary | ★ = highest-privilege action | red arrow = attack path

Worksheet (≈14 min)

1-2 · AGENTS & PRIVILEGES

AGENT / COMPONENT	RUN BY (YOU / VENDOR / USER)	CAN READ / WRITE / EXECUTE	PRIVILEGE

3 · TRUST BOUNDARY

INSIDE (YOU CONTROL)	OUTSIDE (UNTRUSTED)

4 · HIGHEST-PRIVILEGE ACTION (★) AND THE WORST PATH TO IT

5 · ONE CONTROL THAT BREAKS THE PATH

Closing reflection. Did your attack path require a “hacker,” or just *untrusted data* reaching a privileged agent? Most A2A failures are the second kind.

Illustrative for the exercise only. A real threat model is broader and bank-specific. This is a 25-minute scaffold, not a complete security assessment.